

Tổng quan mô-đun

Tên gốc: Network Enumeration with Nmap

Bản dịch: Liệt kê mạng bằng Nmap

Danh mục: Thông thường / Tấn công

Độ khó: Dễ

Tier: 1

Thời gian dự kiến: 7 giờ

Tổng số phần: 12

Bài tập tương tác: 7

Tác giả: Cry0l1t3

Trạng thái: Hoàn thành · +10 Cubes

Mô tả mô-đun

Nmap là công cụ **lập bản đồ và khám phá mạng** được dùng rộng rãi nhờ **kết quả chính xác, hiệu quả**. Cả chuyên gia bảo mật **tấn công** và **phòng thủ** đều sử dụng. Mô-đun đề cập **nền tảng cần thiết** để dùng Nmap **liệt kê mạng hiệu quả**.

Tóm tắt mô-đun

Nmap dùng **nhận diện, quét hệ thống** trên mạng, là thành phần quan trọng trong **chẩn đoán mạng, đánh giá hệ thống kết nối mạng**. Nội dung dạy nền tảng và cách dùng hiệu quả để:

- lập bản đồ mạng;
- nhận diện máy hoạt động;
- quét cổng;
- liệt kê dịch vụ;
- phát hiện hệ điều hành;
- dùng script NSE;
- hiểu tác động tường lửa, IDS, IPS lên liệt kê.

Cấu trúc mô-đun

1. Liệt kê
2. Giới thiệu Nmap
3. Khám phá máy
4. Quét máy và cổng
5. Lưu kết quả
6. Liệt kê dịch vụ
7. Nmap Scripting Engine

8. Hiệu năng

9. Né tránh tường lửa và IDS/IPS

10. Né tránh tường lửa và IDS/IPS — Lab dễ

11. Né tránh tường lửa và IDS/IPS — Lab trung bình

12. Né tránh tường lửa và IDS/IPS — Lab khó

Những việc đã thực hiện cùng nhau trong cuộc trò chuyện gốc

Trong mô-đun, công việc cùng thực hiện gồm:

- dịch trung thành toàn bộ tổng quan sang **tiếng Bồ Đào Nha Brazil**;
- dịch dần **12 phần**;
- tổng hợp **ghi chép rất đầy đủ** từng phần;
- giải thích khái niệm:
 - liệt kê;
 - khám phá máy;
 - quét cổng TCP, UDP;
 - phát hiện phiên bản;
 - thu banner;
 - NSE;
 - tinh chỉnh hiệu năng;
 - đọc hành vi tường lửa/IDS/IPS;
- tổ chức nội dung hướng tới bản **sẵn sàng đăng GitHub, sao lưu PDF**;
- tích hợp **bảng tra chính thức** làm phụ lục.

Ghi chú quan trọng về lab phần 10, 11, 12: Trong cuộc trò chuyện gốc chỉ có **đề bài mở đầu**. Vì vậy ghi chép cuối ghi **bối cảnh, mục đích bài tập, bài học chiến lược, không** có hướng dẫn thực hành đầy đủ từ cuộc trò chuyện đó, vì tài liệu cụ thể chưa được gửi.

Thực hành mô-đun — Lời giải tích hợp

Ngoài lý thuyết trong cuộc trò chuyện gốc, thực hành được tích hợp từ bản xuất trung thành của cuộc trò chuyện thực hành khác. Bản cuối ghi **đã làm gì, gỡ vướng từng bài thể nào, kết quả đạt được**.

Thành tựu

- Hoàn thành mô-đun thành công
- **Phân thưởng:** +10 Cubes

Thực hành 1 — Thu banner thủ công từ dịch vụ đáng ngờ

Bối cảnh

Sau liệt kê rộng, mục tiêu đáng ngờ nhất:

- 31337/tcp open ftp ProFTPD

Cổng 31337 gây chú ý vì rất giống CTF; giả thuyết Nmap mặc định chưa hiển thị toàn banner.

Cách tiếp cận

Tập trung **thu banner thủ công**, ưu tiên cổng 31337.

```
nc -nv [LAB_IP_REDACTED] 31337
```

Kết quả

Dịch vụ trả flag ngay trong banner:

```
220 [LAB_FLAG_REDACTED]
```

Câu trả lời cuối

```
[LAB_FLAG_REDACTED]
```

Bài học thực tế

Khi dịch vụ ở cổng khác thường, gợi ý nói Nmap chưa hiển thị hết, **thu banner thủ công** có thể hiệu quả hơn chỉ tin phát hiện phiên bản tự động.

Thực hành 2 — Liệt kê web bằng NSE, khám phá robots.txt

Bối cảnh

Web chỉ có trang mặc định Apache; dùng script HTTP của NSE tìm dấu vết ẩn.

Cách tiếp cận

```
nmap -Pn -p80 --script http-title,http-headers,http-server-header,http-enum [LAB_IP_REDACTED]
```

Lướt quét cho thấy:

- Apache2 Ubuntu Default Page: It works
- [LAB_CREDENTIAL_REDACTED] (Ubuntu)
- phát hiện /robots.txt bằng http-enum

Sau đó truy cập trực tiếp tệp để liệt kê sâu:

```
curl [LAB_URL_REDACTED]
```

Kết quả

Nội dung robots.txt lộ flag:

```
User-agent: *  
Allow: /  
[LAB_FLAG_REDACTED]
```

Câu trả lời cuối

```
[LAB_FLAG_REDACTED]
```

Bài học thực tế

Ngay cả trang thông thường, **script NSE cho HTTP** có thể nhanh chóng chỉ ra tệp liên quan. http-enum tìm đường quan trọng, curl xác nhận đáp án.

Thực hành 3 — Lab dễ: phát hiện hệ điều hành ít gây chú ý

Bối cảnh

Mục tiêu là tìm hệ điều hành **với ít dấu vết nhất**, xét nguy cơ cảnh báo, bị cấm.

Mục tiêu

- [LAB_IP_REDACTED]

Chiến lược

Quét nhẹ cổng thường gặp trước:

```
nmap -Pn -sS --top-ports 10 --max-retries 1 -T2 -vvv [LAB_IP_REDACTED]
```

Chủ yếu tìm thấy:

- 22/tcp open ssh
- 80/tcp open http

Sau đó xác nhận ít gây chú ý qua banner:

```
nmap -Pn -sV --version-light -p22,80 --max-retries 1 -T2 [LAB_IP_REDACTED]
```

Bảng chứng quan sát

- OpenSSH 7.6p1 Ubuntu 4ubuntu0.7
- Apache httpd 2.4.29 ((Ubuntu))
- Service Info: OS: Linux

Câu trả lời cuối

Ubuntu

Bài học thực tế

Khi lab hỏi hệ điều hành, đáp án có thể là tên **cụ thể hơn được banner tiết lộ**. “Linux” hợp lý nhưng đáp án chính xác là **Ubuntu**.

Thực hành 4 — Lab trung bình: liệt kê DNS qua UDP bằng dns-nsid

Bối cảnh

Lab nhấn mạnh **UDP trên VPN**. Hướng suy luận là ưu tiên DNS ở 53/udp.

Mục tiêu

- [LAB_IP_REDACTED]

Chiến lược

Xác nhận cổng DNS ban đầu:

```
sudo nmap -Pn -sU -p53 --max-retries 1 -T2 [LAB_IP_REDACTED]
```

Sau đó dùng script NSE chuyên biệt:

```
sudo nmap -Pn -sU -p53 -sV --script dns-nsid [LAB_IP_REDACTED]
```

Kết quả

dns-nsid truy vấn bind.version, lộ trực tiếp flag:

[LAB_FLAG_REDACTED]

Câu trả lời cuối

[LAB_FLAG_REDACTED]

Bài học thực tế

Với DNS, script NSE chuyên biệt có thể có giá trị hơn quét UDP chung. **UDP 53** kết hợp ****dns-nsid**** đủ giải bài.

Thực hành 5 — Lab khó: cổng ẩn, né lọc bằng cổng nguồn, banner thủ công

Bối cảnh

Bài mất công nhất. Mục tiêu chỉ hiện banner thông thường ở 22/tcp, 80/tcp; khó khăn là tìm **dịch vụ bổ sung được bộ lọc bảo vệ và cách giao tiếp khiến nó phản hồi**.

Mục tiêu

- [LAB_IP_REDACTED]

Giai đoạn 1 — Liệt kê với --source-port 53

Dùng **cổng nguồn 53**, giả thuyết tường lửa dễ cho phép lưu lượng giống DNS hơn.

```
sudo nmap -Pn -n -sS -p- --open --max-retries 1 -T2 --source-port 53 -vvv [LAB_IP_REDACTED]
```

Ban đầu chỉ tìm:

- 22/tcp open ssh
- 80/tcp open http

Liệt kê phiên bản các cổng đã thấy:

```
sudo nmap -Pn -n -sV --version-all -p22,80 --source-port 53 --max-retries 1 -T3 [LAB_IP_REDACTED]
sudo nmap -Pn -n -sV --version-all --script=banner -p22,80 --source-port 53 --max-retries 1 -T3
[LAB_IP_REDACTED]
sudo nmap -Pn -n -p80 -sV --version-all --script=http-title,http-headers,banner --source-port 53
--max-retries 1 -T3 [LAB_IP_REDACTED]
```

Chỉ có banner thông thường:

- OpenSSH 7.6p1 Ubuntu 4ubuntu0.7
- Apache httpd 2.4.29 ((Ubuntu))
- Apache2 Ubuntu Default Page: It works

Giai đoạn 2 — Giả thuyết đã loại

Chưa có đáp án nên tiếp tục giả thuyết lần lượt.

Giả thuyết A — Cơ sở dữ liệu

Thử cổng dịch vụ cơ sở dữ liệu thường gặp:

```
sudo nmap -Pn -n -sS -p3306,5432,1433,1521,27017,6379 --open --max-retries 1 -T3 --source-port 53 -f
[LAB_IP_REDACTED]
```

Giả thuyết B — Lưu trữ/chia sẻ

Thủ cổng NFS, SMB, rsync và tương tự:

```
sudo nmap -Pn -n -sS -p21,111,139,445,873,2049,3260 --open --max-retries 1 -T3 --source-port 53 -f -vvv [LAB_IP_REDACTED]
```

Thủ cổng nguồn 20, 21, 2049, 111, quét UDP 111, 2049.

Dù kiểm tra nhiều, kết quả gần như chỉ 22/tcp, 80/tcp, cho thấy dịch vụ ẩn không ở đường dễ thấy nhất.

Giai đoạn 3 — Tìm cổng ẩn

Bước ngoặt là tập trung **cổng 50000**, vẫn dùng nguồn 53:

```
sudo nmap -Pn -n -p50000 --source-port 53 [LAB_IP_REDACTED]
```

Kết quả trung gian

```
50000/tcp open ibm-db2
```

Cổng liên quan cuối cùng xuất hiện mở.

Giai đoạn 4 — Kết nối thủ công để buộc dịch vụ phản hồi

nc, ncst tới 50000 chỉ mở phiên, không tự trả banner. Bước cuối gửi đầu vào tối thiểu:

```
printf '\n' | sudo ncst -nv --source-port 53 [LAB_IP_REDACTED] 50000
```

Kết quả cuối

Phản hồi dịch vụ mang flag trực tiếp:

```
220 [LAB_FLAG_REDACTED]
500 Invalid command: try being more creative
```

Câu trả lời cuối

```
[LAB_FLAG_REDACTED]
```

Bài học lab khó

- tìm đúng cổng chưa luôn đủ; đôi khi phải **khiến dịch vụ trả lời thủ công**;
- -sv có thể ghi tcpwrapped nhưng chưa hiện thông tin mà kết nối thủ công đơn giản sẽ lộ;
- cần **đổi giả thuyết, đổi cổng nguồn, tìm cổng ẩn, tương tác banner thủ công**.

Tổng hợp thực hành

Bài đã giải và đáp án

1. Thu banner ProFTPD thủ công ở 31337

Đáp án: [LAB_FLAG_REDACTED]

2. Liệt kê HTTP tới robots.txt

Đáp án: [LAB_FLAG_REDACTED]

3. Lab dễ — Hệ điều hành mục tiêu

Đáp án: Ubuntu

4. Lab trung bình — DNS qua UDP 53 / dns-nsid

Đáp án: [LAB_FLAG_REDACTED]

5. Lab khó — Dịch vụ ẩn ở 50000 với cổng nguồn 53

Đáp án: [LAB_FLAG_REDACTED]

Điều thực hành củng cố

- thu banner thủ công vẫn thiết yếu;
- script NSE đúng tiết kiệm nhiều thời gian;
- với bộ lọc, IDS/IPS, **loại quét, nhịp thời gian, cổng nguồn, mức dấu vết** thay đổi hoàn toàn kết quả;
- dịch vụ trông “vô hại” trong đầu ra mặc định có thể giấu manh mối;
- kết nối nc/ncat vẫn quyết định khi tự động hóa chưa làm rõ vấn đề.

Mục tiêu học tập

Khi kết thúc, đã nắm:

- **tư duy liệt kê đúng**;
- **Nmap** khám phá máy hoạt động;
- diễn giải trạng thái cổng;
- phân biệt **SYN scan**, **Connect scan**, **UDP scan**;
- phát hiện dịch vụ, phiên bản bằng `-sV`;
- lưu bằng `-oN`, `-oG`, `-oX`, `-oA`;
- **NSE** mở rộng liệt kê, phân loại ban đầu;
- điều chỉnh hiệu năng mà không mất quá nhiều khả năng quan sát;
- hiểu khái niệm tác động của tường lửa, IDS, IPS.

Nền tảng cốt lõi

1. Liệt kê là chìa khóa

Thông điệp phần đầu:

Mục tiêu không phải “xâm nhập ngay”; mục tiêu là hiểu mục tiêu nhiều nhất có thể.

Liệt kê thu tối đa thông tin hữu ích về:

- máy;
- cổng;
- dịch vụ;
- phiên bản;
- hệ điều hành;
- banner;
- hành vi mạng;
- kiểm soát phòng thủ;
- bề mặt tấn công tiềm năng.

Càng nhiều thông tin đúng, càng dễ:

- xây giả thuyết;

- tìm hướng tấn công;
- xác minh thực tế và nhiễu;
- tránh phí thời gian đường sai.

2. Công cụ không thay hiểu biết

Điểm quan trọng:

- công cụ hỗ trợ;
- **không thay thế** hiểu biết giao thức, dịch vụ.

Ưu thế nằm ở biết:

- dịch vụ thường phản hồi thế nào;
- không phản hồi có ý nghĩa gì;
- đâu là banner thật, đâu là suy luận Nmap;
- khi nào trình quét đúng;
- khi nào trình quét có thể bỏ bối cảnh.

3. Liệt kê thủ công vẫn quan trọng

Trình quét tăng tốc nhưng không luôn hiện mọi thứ. Ví dụ:

- khám phá bằng ARP so với ICMP;
- UDP không phản hồi;
- banner giàu thông tin hơn đầu ra cuối Nmap;
- filtered cần diễn giải;
- tinh chỉnh hiệu năng có thể gây âm tính giả.

Bảng tra chính

Cú pháp cơ bản

`nmap <scan types> <options> <target>`

Khám phá máy

```
sudo nmap [LAB_IP_REDACTED]/24 -sn -oA tnet
sudo nmap -sn -oA tnet -iL hosts.lst
sudo nmap [LAB_IP_REDACTED] -sn -oA host
sudo nmap [LAB_IP_REDACTED] -sn -oA host -PE --packet-trace --disable-arp-ping
```

Quét cổng TCP

```
sudo nmap -sS localhost
sudo nmap [LAB_IP_REDACTED] --top-ports=10
sudo nmap [LAB_IP_REDACTED] -p 21 --packet-trace -Pn -n --disable-arp-ping
sudo nmap [LAB_IP_REDACTED] -p 443 --packet-trace --disable-arp-ping -Pn -n --reason -sT
```

Quét cổng UDP

```
sudo nmap [LAB_IP_REDACTED] -F -sU
sudo nmap [LAB_IP_REDACTED] -sU -Pn -n --disable-arp-ping --packet-trace -p 137 --reason
```

Lưu kết quả

```
sudo nmap [LAB_IP_REDACTED] -p- -oA target
xsltproc target.xml -o target.html
```

Liệt kê dịch vụ

```
sudo nmap [LAB_IP_REDACTED] -p- -sV
sudo nmap [LAB_IP_REDACTED] -p- -sV --stats-every=5s
sudo nmap [LAB_IP_REDACTED] -p- -sV -v
```

Thu banner bổ sung

```
sudo tcpdump -i eth0 host [LAB_IP_REDACTED] and [LAB_IP_REDACTED]
nc -nv [LAB_IP_REDACTED] 25
```

NSE

```
sudo nmap <target> -sC
sudo nmap <target> --script <category>
sudo nmap <target> --script <script1>,<script2>
sudo nmap [LAB_IP_REDACTED] -p 25 --script banner,smtp-commands
sudo nmap [LAB_IP_REDACTED] -p 80 -A
sudo nmap [LAB_IP_REDACTED] -p 80 -sV --script vuln
```

Hiệu năng

```
sudo nmap [LAB_IP_REDACTED]/24 -F
sudo nmap [LAB_IP_REDACTED]/24 -F --initial-rtt-timeout 50ms --max-rtt-timeout 100ms
sudo nmap [LAB_IP_REDACTED]/24 -F --max-retries 0
sudo nmap [LAB_IP_REDACTED]/24 -F --min-rate 300
sudo nmap [LAB_IP_REDACTED]/24 -F -T 5
```

Ghi chép đầy đủ từng phần

Phần 1 — Liệt kê

Ý chính

Liệt kê là phần quan trọng nhất. Không nhằm “truy cập nhanh” mà **nhận diện mọi hình thức tấn công khả thi**, từ lượng thông tin đáng tin cậy lớn nhất.

Các điểm chính

- Công cụ chỉ hữu ích khi biết dùng dữ liệu trả về.
- Cần hiểu:
 - cách dịch vụ hoạt động;
 - cú pháp;
 - cách tương tác đúng.
- Liệt kê là thu thông tin tối đa.
- Liệt kê càng tốt, càng rõ:
 - hướng tấn công;
 - cấu hình sai;
 - hành vi bất thường;
 - đường khai thác thực tế.

Hai mục tiêu chính

1. Tìm **chức năng**, **tài nguyên** cho phép tương tác mục tiêu.
2. Tìm **thông tin bổ sung** thuận lợi cho truy cập hệ thống.

Bài học

- Liệt kê là chìa khóa.
 - Công cụ thiếu diễn giải kỹ thuật cho kết quả kém.
 - Liệt kê thủ công là thành phần quan trọng.
 - Cấu hình sai, lơ là phòng thủ thường cho manh mối quý.
-

Phần 2 — Giới thiệu Nmap

Nmap là gì

Công cụ mã nguồn mở để:

- phân tích mạng;
- kiểm toán bảo mật;
- khám phá máy;
- liệt kê cổng;
- phát hiện dịch vụ;
- nhận diện hệ điều hành.

Trường hợp sử dụng

- kiểm toán bảo mật;
- hỗ trợ kiểm thử xâm nhập;
- xác minh tường lửa, IDS;
- lập bản đồ mạng;
- phân tích phản hồi;
- nhận diện cổng mở;
- hỗ trợ đánh giá lỗ hổng.

Kiến trúc logic sử dụng

1. Khám phá máy
2. Quét cổng
3. Liệt kê, phát hiện dịch vụ
4. Phát hiện hệ điều hành
5. Tương tác bằng script NSE

Loại quét được trình bày

- -sS → quét SYN
- -sT → quét TCP Connect

- -sA → quét ACK
- -sU → quét UDP
- -sN, -sF, -sX → Null, FIN, Xmas
- -sO → quét giao thức IP
- -sI → quét Idle
- --scanflags → tùy chỉnh cờ

Quét SYN (-sS)

Một trong các phương pháp quan trọng nhất.

Hành vi

- gửi SYN;
- nhận SYN-ACK → **open**;
- nhận RST → **closed**;
- không phản hồi → thường **filtered**.

Ưu điểm

- nhanh;
- phổ biến;
- không hoàn tất bắt tay ba bước.

Ví dụ

```
sudo nmap -sS localhost
```

Đầu ra cho thấy

- máy cục bộ hoạt động;
- bốn cổng TCP mở;
- quan hệ cổng, trạng thái, dịch vụ.

Bài học

- Nmap không chỉ là “trình quét cổng”.
- Là nền tảng liệt kê.
- Hiểu logic quan trọng ngang chạy lệnh.

Phần 3 — Khám phá máy

Ý chính

Trước quét dịch vụ, cổng, cần biết: **máy nào hoạt động?**

Lệnh cơ bản

```
sudo nmap [LAB_IP_REDACTED]/24 -sn -oA tnet
```

Cờ chính

- -sn → tắt quét cổng, tập trung khám phá máy
- -oA → lưu mọi định dạng
- -iL → đọc mục tiêu từ tệp

Các cách được trình bày

Quét subnet

```
sudo nmap [LAB_IP_REDACTED]/24 -sn -oA tnet
```

Quét danh sách IP

```
sudo nmap -sn -oA tnet -iL hosts.lst
```

Quét nhiều IP

```
sudo nmap -sn -oA tnet [LAB_IP_REDACTED] [LAB_IP_REDACTED] [LAB_IP_REDACTED]
```

Quét khoảng giá trị octet

```
sudo nmap -sn -oA tnet [LAB_IP_REDACTED]-20
```

ARP so với ICMP

Một phần hữu ích nhất.

Thực hành cho thấy

Ngay cả dùng -PE, trên mạng cục bộ Nmap có thể nhận máy hoạt động **qua ARP**, trước khi dùng ICMP.

Công cụ xác minh

- --packet-trace
- --reason
- --disable-arp-ping

Bài học

“Host is up” không luôn mang cùng ý nghĩa. Có thể do:

- phản hồi ARP;
- phản hồi ICMP;
- bằng chứng khác.

Điều rút ra

- Không phản hồi không tự động nghĩa là máy không tồn tại.
- Tường lửa, bộ lọc có thể giấu máy hoạt động.
- Xác minh lý do “host up” thuộc liệt kê thành thạo.

Phần 4 — Quét máy và cổng

Trạng thái cổng Nmap

Sáu trạng thái:

- open
- closed
- filtered
- unfiltered
- open|filtered
- closed|filtered

Diễn giải ngắn

- **open** → dịch vụ chấp nhận tương tác
- **closed** → cổng truy cập được, không có dịch vụ lắng nghe
- **filtered** → không kết luận được do bộ lọc/tường lửa
- **unfiltered** → truy cập được, chưa xác định mở hay đóng
- **open|filtered** → thường ở UDP hoặc ít phản hồi
- **closed|filtered** → bối cảnh riêng như idle scan

Tìm TCP mở

Ví dụ

```
sudo nmap [LAB_IP_REDACTED] --top-ports=10
sudo nmap [LAB_IP_REDACTED] -p 21 --packet-trace -Pn -n --disable-arp-ping
sudo nmap [LAB_IP_REDACTED] -p 443 --packet-trace --disable-arp-ping -Pn -n --reason -sT
```

Quét SYN so với Connect

-sS

- kín đáo hơn;
- không hoàn tất bắt tay;
- phổ biến trong liệt kê.

-sT

- hoàn tất bắt tay;
- thường nhiều dấu vết hơn;
- khá chính xác.

Cổng bị lọc

Khác biệt:

Drop — Bỏ gói

- không phản hồi;
- truyền lại;

- chậm hơn;
- kết quả thường `filtered`.

Reject — Từ chối

- phản hồi rõ;
- giúp suy luận hành vi phòng thủ.

Quét UDP

Ví dụ

```
sudo nmap [LAB_IP_REDACTED] -F -sU
```

Quy tắc UDP quan trọng

- dịch vụ trả UDP → **open**
- ICMP type 3 code 3 → **closed**
- không phản hồi → thường **open|filtered**

Bài học

- Kết quả cổng cần diễn giải theo bối cảnh.
- TCP, UDP có logic khác nhau nhiều.
- `filtered` là tín hiệu phòng thủ, vẫn hữu ích.

Phần 5 — Lưu kết quả

Mục tiêu

Lưu quét thuộc quy trình chuyên nghiệp, không phải chi tiết phụ.

Định dạng đầu ra

-oN

Đầu ra thông thường; đuôi `.nmap`.

-oG

Đầu ra thuận tiện grep; đuôi `.gnmap`.

-oX

Đầu ra XML; đuôi `.xml`.

-oA

Lưu tất cả cùng lúc.

Lệnh chính

```
sudo nmap [LAB_IP_REDACTED] -p- -oA target
```

Tập tạo ra

- target.nmap
- target.gnmap
- target.xml

Cách dùng thực tế

.nmap

Phù hợp người đọc.

.gnmap

Phù hợp phân tích nhanh bằng:

- grep
- cut
- awk
- sed

.xml

Phù hợp:

- tự động hóa;
- phân tích có cấu trúc;
- tích hợp;
- báo cáo.

Chuyển XML sang HTML

```
xsltproc target.xml -o target.html
```

Bài học

- Quét lưu được giúp xem lại, đối chiếu, ghi chép.
- -oA là thói quen mặc định tốt.
- XML tái sử dụng tốt nhất cho tự động hóa, báo cáo.

Phần 6 — Liệt kê dịch vụ

Mục tiêu

Tìm **dịch vụ** nào chạy, **phiên bản** nào lộ ra.

Lệnh cơ bản

```
sudo nmap [LAB_IP_REDACTED] -p- -sV
```

-sV làm gì

Cổ nhận diện:

- tên dịch vụ;
- phiên bản;
- đôi khi hostname;
- đôi khi hệ điều hành;
- đôi khi CPE.

Theo dõi lượt quét dài

Phím cách

Trong khi quét, phím cách hiện trạng thái tạm.

--stats-every

```
sudo nmap [LAB_IP_REDACTED] -p- -sV --stats-every=5s
```

Mức chi tiết

```
sudo nmap [LAB_IP_REDACTED] -p- -sV -v
```

Hiện cổng mở ngay khi tìm được.

Thu banner

Nmap thường dùng banner trực tiếp; nếu chưa đủ, đối chiếu dấu hiệu đã biết.

Điểm rất quan trọng

Đầu ra cuối không luôn hiện mọi thứ dịch vụ thực sự trả về.

Ví dụ SMTP

Banner thủ công cho nhiều bối cảnh hơn tóm tắt Nmap:

- hostname;
- phần mềm;
- gợi ý bản phân phối Linux.

Công cụ bổ sung

nc

```
nc -nv [LAB_IP_REDACTED] 25
```

tcpdump

```
sudo tcpdump -i eth0 host [LAB_IP_REDACTED] and [LAB_IP_REDACTED]
```

Luồng TCP quan sát

1. SYN
2. SYN-ACK
3. ACK
4. PSH-ACK (banner/dữ liệu)

Bài học

- Cổng mở không có phiên bản mới là nửa công việc.
 - Banner thủ công có thể lộ hơn phần tóm tắt.
 - nc, tcpdump bổ sung tốt cho Nmap.
-

Phần 7 — Nmap Scripting Engine (NSE)

NSE là gì

Cho phép dùng script **Lua** tương tác dịch vụ cụ thể.

Nhóm liên quan

- default — mặc định
- discovery — khám phá
- safe — an toàn
- version — phiên bản
- auth — xác thực
- brute — thử vét cạn
- intrusive — can thiệp
- exploit — khai thác
- dos — từ chối dịch vụ
- vuln — lỗ hổng

Cách dùng

Script mặc định

```
sudo nmap <target> -sC
```

Toàn nhóm

```
sudo nmap <target> --script <category>
```

Script cụ thể

```
sudo nmap <target> --script <script1>,<script2>
```

Ví dụ SMTP

```
sudo nmap [LAB_IP_REDACTED] -p 25 --script banner,smtp-commands
```

Kết quả

- banner SMTP;
- nhận diện Postfix;
- gợi ý Ubuntu;
- lệnh máy chủ hỗ trợ.

-A

Quét mạnh kết hợp:

- -sV
- -O
- --traceroute
- script mặc định (-sc)

Ví dụ

```
sudo nmap [LAB_IP_REDACTED] -p 80 -A
```

--script vuln

Dùng phân loại ban đầu lỗi hổng đã biết.

Ví dụ

```
sudo nmap [LAB_IP_REDACTED] -p 80 -sV --script vuln
```

Nội dung xuất hiện

- dấu hiệu WordPress;
- trang quản trị;
- tên người dùng admin;
- tham chiếu CVE liên quan Apache 2.4.29.

Bài học

- NSE biến Nmap thành công cụ liệt kê chủ động.
- -sc là mức khởi đầu tốt.
- --script vuln hỗ trợ phân loại, không thay xác minh thủ công.
- -A tiện nhưng nhiều dấu vết, ít kiểm soát hơn.

Phần 8 — Hiệu năng

Ý chính

Điều chỉnh tăng tốc có thể giảm khả năng quan sát.

RTT — Thời gian khứ hồi

Ví dụ

```
sudo nmap [LAB_IP_REDACTED]/24 -F --initial-rtt-timeout 50ms --max-rtt-timeout 100ms
```

Bài học

Giảm RTT quá mức có thể:

- bỏ sót máy;
- coi chậm là vắng mặt;
- gây âm tính giả.

Số lần thử lại

Ví dụ

```
sudo nmap [LAB_IP_REDACTED]/24 -F --max-retries 0
```

Bài học

Ít thử lại = nhanh hơn nhưng:

- ít kiên trì;
- dễ bỏ sót cổng thật hơn.

Min-rate — Tốc độ tối thiểu

Ví dụ

```
sudo nmap [LAB_IP_REDACTED]/24 -F --min-rate 300
```

Bài học

Môi trường kiểm soát, tăng tốc tối thiểu có thể nhanh hơn nhiều mà ít mất thông tin. Môi trường nhạy cảm có thể:

- tạo dấu vết;
- kích hoạt giám sát;
- gây chận.

Mẫu -T

- -T0 → paranoid — cực kỳ thận trọng
- -T1 → sneaky — kín đáo
- -T2 → polite — nhẹ nhàng
- -T3 → normal — thông thường
- -T4 → aggressive — mạnh
- -T5 → insane — cực mạnh

Bài học

- Tinh chỉnh luôn cân bằng tốc độ, độ tin cậy.
- -T4 thường hữu ích trong lab, mạng tốt.
- -T5 có thể dùng được nhưng không nên tự động làm mặc định.

Phần 9 — Né tránh tường lửa và IDS/IPS

Phạm vi ghi chép

Trong cuộc trò chuyện gốc, phần này tổng hợp **mức khái niệm**, không chi tiết thao tác.

Khái niệm chính

Tường lửa

Quyết định lưu lượng:

- đi vào;
- bị bỏ;
- bị từ chối;
- được phép.

IDS

Quan sát, cảnh báo.

IPS

Quan sát, tự phản ứng.

Drop so với Reject

Drop

- im lặng;
- hết thời gian chờ;
- nhiều bất định.

Reject

- trả rõ;
- thêm bối cảnh;
- suy luận quy tắc tốt hơn.

Điểm trọng tâm

Hành vi công còn phụ thuộc:

- loại gói;
- nguồn lưu lượng;
- chính sách tường lửa;
- giám sát IDS/IPS;
- bối cảnh giao tiếp.

Bài học

- `filtered` cần diễn giải theo bối cảnh.
- Phòng thủ có thể tạo âm tính giả.
- Hành vi phòng thủ thay đổi cách đọc quét.

Phần 10 — Né tránh tường lửa và IDS/IPS — Lab dễ

Nội dung được gửi trong cuộc trò chuyện gốc

Chỉ đề bài mở đầu.

Lab dạy gì

- có IDS/IPS hoạt động;
- có đếm cảnh báo;
- nguy cơ bị cấm;
- kiểm thử ít gây chú ý nhất có thể.

Điểm chính

status.php phản hồi hành vi phòng thủ, giúp tương quan:

- thao tác;
- tăng cảnh báo;
- tác động vận hành.

Bài học

- môi trường phản ứng hành vi người tấn công;
 - mỗi thao tác có chi phí;
 - tập trung **kiểm soát dấu vết**.
-

Phần 11 — Né tránh tường lửa và IDS/IPS — Lab trung bình

Nội dung được gửi trong cuộc trò chuyện gốc

Chỉ đề bài mở đầu.

Lab dạy gì

Sau kiểm thử đầu:

- quản trị viên đổi IDS/IPS;
- tường lửa nghiêm hơn;
- lưu lượng bị lọc mạnh hơn.

Gợi ý quan trọng

Bài nhấn mạnh **UDP trên VPN**.

Bài học

- môi trường phòng thủ tiến triển;
 - cách từng hiệu quả có thể ngừng hiệu quả;
 - cần thích nghi cách đọc tình huống;
 - giao thức vận chuyển, bối cảnh quan trọng.
-

Phần 12 — Né tránh tường lửa và IDS/IPS — Lab khó

Nội dung được gửi trong cuộc trò chuyện gốc

Chỉ đề bài mở đầu.

Lab dạy gì

Đội phòng thủ:

- đã đào tạo;
- thận trọng hơn;
- thay dịch vụ;
- sửa giao tiếp phần mềm.

Ý chính

Môi trường:

- trưởng thành hơn;
- thích nghi hơn;
- ý thức hơn;
- ít cho phép hơn.

Bài học

- phòng thủ cũng học;
 - lắp mù quảng cách trước là sai;
 - cần đánh giá lại sau thay dịch vụ, giao tiếp.
-

Bảng cờ quan trọng nhất

Cờ / tùy chọn	Chức năng chính	Ghi chú thực tế
-sn	Khám phá máy, không quét cổng	Tốt để lập bản đồ máy hoạt động
-PE	ICMP Echo Request	Trên mạng cục bộ có thể có ARP trước
--packet-trace	Hiện gói gửi/nhận	Rất tốt cho học tập
--reason	Hiện lý do kết quả	Hữu ích diễn giải open, closed, filtered
-sS	Quét SYN	Nhanh, phổ biến
-sT	TCP Connect	Hoàn tất bắt tay
-sU	Quét UDP	Chậm, mơ hồ hơn
-p-	Tắt cả cổng TCP	Quét đầy đủ
--top-ports=10	10 cổng phổ biến nhất	Trình sát nhanh
-F	100 cổng phổ biến nhất	Mức khởi đầu tốt
-sV	Phát hiện dịch vụ/phiên bản	Thiết yếu sau tìm cổng mở
-v / -vv	Mức chi tiết	Hiện tiến độ, phát hiện trực tiếp
-oN	Lưu đầu ra thường	Người đọc
-oG	Lưu dạng grep	Phân tích bằng shell
-oX	Lưu XML	Tích hợp, tự động hóa
-oA	Lưu mọi định dạng	Lựa chọn chung tốt nhất
-sC	Script NSE mặc định	Khởi đầu liệt kê tốt
--script vuln	Script phân loại lỗ hổng	Hữu ích ưu tiên
-A	Quét mạnh	Tiện, nhiều dấu vết hơn
--stats-every=5s	Hiện tiến độ định kỳ	Hữu ích lướt dài
--initial-rtt-timeout	Chờ RTT ban đầu	Quá thấp có thể bỏ máy
--max-rtt-timeout	Chờ RTT tối đa	Kiểm soát thời gian chờ
--max-retries	Số lần thử	Ít thử tăng nguy cơ âm tính giả
--min-rate	Tốc độ gói tối thiểu	Hữu ích môi trường kiểm soát
-T0 tới -T5	Mẫu thời gian	Cân bằng kín đáo, tốc độ, tin cậy

Lỗi và bẫy thường gặp

1. Coi không phản hồi là máy không hoạt động

Có thể do:

- tường lửa;
- lọc ICMP;

- chính sách bỏ gói;
- mạng chậm.

2. Coi filtered không có giá trị

Thực tế cung cấp thông tin hành vi phòng thủ.

3. Nghĩ -sV luôn hiện mọi thứ

Không luôn vậy. Banner thủ công có thể lộ hơn tóm tắt Nmap.

4. Tinh chỉnh mạnh không so kết quả

Tốc độ thiếu xác minh có thể giấu:

- máy;
- cổng;
- phản hồi chậm.

5. Chạy NSE không cân nhắc dấu vết

Một số script an toàn, số khác mạnh hơn.

6. Tin một lượt quét đủ liệt kê

Kết quả tốt thường kết hợp:

- quét nhanh;
- quét đầy đủ;
- phát hiện phiên bản;
- liệt kê thủ công;
- xác minh đầu ra.

Tổng kết mô-đun

Xây nền tảng đầy đủ **liệt kê bằng Nmap**:

- liệt kê là bước quan trọng nhất trình sát;
- logic khám phá máy;
- đọc trạng thái cổng đúng;
- khác biệt TCP, UDP;
- phát hiện phiên bản, thu banner;
- dùng NSE thực tế;
- lưu, tái dùng đầu ra;
- tác động tinh chỉnh hiệu năng;
- tương tác khái niệm giữa quét, tường lửa, IDS, IPS.

Một câu

Dùng Nmap tốt không chỉ chạy lệnh: phải hiểu sâu mạng trả gì, giấu gì, vì sao.

Nội dung nên ôn tiếp

1. ARP khác ICMP khi khám phá máy;
 2. open, closed, filtered, open|filtered;
 3. -sS, -sT, -sU;
 4. diễn giải banner, giới hạn -sV;
 5. khi dùng -oA;
 6. khi dùng -sC, -A, --script vuln;
 7. tác động --min-rate, --max-retries, mẫu -T;
 8. phòng thủ thay đổi cách đọc liệt kê.
-

Danh sách tự đánh giá

- [x] Hiểu liệt kê là nền tảng quy trình tấn công
 - [x] Dùng -sn khám phá máy
 - [x] Phân biệt ARP ping với ICMP Echo Request
 - [x] Diễn giải trạng thái cổng Nmap
 - [x] Phân biệt -sS, -sT, -sU
 - [x] Dùng -sV phát hiện phiên bản
 - [x] Biết khi bổ sung nc, tcpdump
 - [x] Lưu .nmap, .gnmap, .xml
 - [x] Dùng -oA mặc định
 - [x] Dùng -sC, script NSE cụ thể
 - [x] Hiểu tinh chỉnh có thể tạo âm tính giả
 - [x] Hiểu khái niệm tác động tường lửa/IDS/IPS
-

Phụ lục — Bảng tra chính thức mô-đun HTB

Phụ lục tổng hợp nội dung **bảng tra chính thức** được mô-đun cung cấp, nay chuyển sang tiếng Việt.

Tùy chọn quét

Tùy chọn	Ý nghĩa
[LAB_IP_REDACTED]/24	Dải mạng mục tiêu
-sn	Tắt quét cổng
-Pn	Tắt ICMP Echo Request
-n	Tắt phân giải DNS
-PE	Quét ping bằng ICMP Echo Request
--packet-trace	Hiện mọi gói gửi, nhận
--reason	Hiện lý do kết quả cụ thể
--disable-arp-ping	Tắt ARP ping
--top-ports=<num>	Quét số cổng phổ biến chỉ định
-p-	Quét mọi cổng
-p22-110	Quét cổng 22 tới 110
-p22,25	Chỉ quét 22, 25
-F	Quét 100 cổng phổ biến
-sS	TCP SYN scan
-sA	TCP ACK scan
-sU	UDP scan
-sV	Phát hiện dịch vụ, phiên bản
-sC	Script NSE nhóm default
--script <script>	Chạy script NSE chỉ định
-O	Phát hiện hệ điều hành
-A	Phát hiện hệ điều hành, dịch vụ, traceroute
-D RND:5	Dùng 5 nguồn đánh lạc hướng ngẫu nhiên
-e	Chọn giao diện mạng
-S [LAB_IP_REDACTED]	Đặt IP nguồn
-g	Đặt cổng nguồn
--dns-server <ns>	Phân giải DNS qua máy chủ tên chỉ định

Tùy chọn đầu ra

Tùy chọn	Ý nghĩa
-oA <filename>	Lưu mọi định dạng khả dụng
-oN <filename>	Lưu dạng thường
-oG <filename>	Lưu dạng grep
-oX <filename>	Lưu XML

Tùy chọn hiệu năng

Tùy chọn	Ý nghĩa
--max-retries <num>	Số lần thử lại
--stats-every=5s	Hiện trạng thái mỗi 5 giây
-v / -vv	Đầu ra chi tiết
--initial-rtt-timeout 50ms	RTT ban đầu
--max-rtt-timeout 100ms	RTT tối đa
--min-rate 300	Số gói gửi đồng thời tối thiểu theo ghi chép gốc
-T <0-5>	Mẫu thời gian

Dùng phụ lục

Tra nhanh để:

- ôn cở không đọc lại toàn mô-đun;
- nhớ chức năng tùy chọn thường gặp;
- xây lượt quét trình sát nhanh;
- ôn đầu ra, tinh chỉnh hiệu năng.

Kết luận

Đã hoàn thành: Network Enumeration with Nmap

Nền tảng tốt cho trình sát, liệt kê, xác minh bề mặt tấn công tiếp theo. Lợi ích chính không phải thuộc lệnh rời rạc mà đọc thành thạo hơn:

- giao thức;
- phản hồi;
- bối cảnh;
- phòng thủ;
- bằng chứng.

Ghi công: Ghi chép gốc của Gabriel Martorelli — kho nguồn

([https://\[LAB_CREDENTIAL_REDACTED\]/hack-the-box-academy-notes](https://[LAB_CREDENTIAL_REDACTED]/hack-the-box-academy-notes)). Đây là bản dịch tiếng Việt, không phải tài liệu chính thức của Hack The Box Academy. Xem [ATTRIBUTION.md](#) ([ATTRIBUTION.md](#)) và [LICENSE](#) ([LICENSE](#)).